register-id

Citizen Registration Gateway

Business requirements

Asian Institute of Technology · MOSIP Asia Digital Public Infrastructure · 12 November 2026

These requirements describe what the gateway must do for a person enrolling in a browser. They cover accessibility, security, modularity, and standardization. Each item records whether the prototype on 12 November 2026 already meets it.

Four reviews were drafted in parallel, one per theme, against the running enroll, sweep, credential, and IDRepo paths. Where those reviews disagreed, the rule below is the one that keeps a UIN from meaning more than the gateway actually checked.

Contents

1 The current software path 1

1.1 Enrollment . . . 1

1.2 1:1 authentication . . . 2

2 Rules that settle the disagreements 2

3 Accessibility 3

BR-A-01 Phone and desktop . . . 3

BR-A-02 Camera failure . . . 3

BR-A-03 Plain language in Thai and English . . . 3

BR-A-04 Keyboard, screen reader, and contrast . . . 4

BR-A-05 Motion and direction . . . 4

BR-A-06 An alternative to the five-pose sweep . . . 4

BR-A-07 Assisted enrollment . . . 5

BR-A-08 Time, pause, and a clear screen . . . 5

4 Security 5

BR-S-01 What a pass is allowed to mean . . . 5

BR-S-02 Single-use challenges . . . 5

BR-S-03 A new session needs a fresh capture . . . 6

BR-S-04 The password stays in Keycloak . . . 6

BR-S-05 Who may see a face . . . 6

BR-S-06 Consent before capture . . . 6

BR-S-07 An override is an exception . . . 7

BR-S-08 Audit of enroll and credential issue . . . 7

BR-S-09 The same bar for storing a face . . . 7

5 Modularity 7

BR-M-01 IDRepo writes the citizen . . . 7
BR-M-02 Keycloak writes the login . . . 8
BR-M-03 Mock or real MOSIP by configuration . . . 8
BR-M-04 No direct database access . . . 8
BR-M-05 Replaceable checks . . . 8
BR-M-06 Downstream systems keep their own records . . . 9
BR-M-07 Django and Celery stay off the identity path . . . 9
BR-M-08 One owner per piece . . . 9

6 Standardization **9**
BR-T-01 UIN is the only citizen identifier . . . 10
BR-T-02 A small demographic set . . . 10
BR-T-03 CBEFF is the biometric of record . . . 10
BR-T-04 The published IDRepo contract . . . 10
BR-T-05 Claims match the check that ran . . . 11
BR-T-06 Credential issue stops at Keycloak . . . 11
BR-T-07 A versioned portal contract . . . 11
BR-T-08 Staging and production make the same promise . . . 11

7 Where the prototype stands **12**

1 The current software path

The picture of the running path is `docs/diagrams/current-system.pdf`, compiled from `docs/diagrams/current-system.tex`. It is one sheet with two bands, Enroll and 1:1 authenticate, read from left to right. The three columns are the browser (`src/project/web/templates/index.html` and face-api.js 1.7.12), the FastAPI server (`src/register_id/api.py`), and PostgreSQL, which the gateway reaches only through the IDRepo REST service. A solid arrow is a request. A dashed arrow is a response. A rose box is a neural net loaded or run in the page. An amber box is the server vector, a hash of the JPEG bytes and not a face model. Clicking a box in that PDF opens the function behind it.

1.1 Enrollment

The person opens the portal and the page loads its weights from the jsDelivr CDN. On each camera frame, SSD MobileNet v1 finds a face box and the 68-landmark net finds the eyes, the nose, and the jaw. The face-recognition net is loaded into the page and left idle. The browser never computes a 128-dimensional descriptor, and it never sends landmarks or a vector.

From those landmarks the page does ordinary arithmetic. It tracks the eye-aspect ratio and a blink count, estimates yaw, and bins that yaw into five sectors from the person's left shoulder to the right: far-left, left, front, right, and far-right. Each accepted frame is kept as a JPEG data URL at quality 0.8. A live enrollment waits until all five sectors have a frame. A still photo is a single frontal JPEG and does not carry the five views.

When the person submits, the page calls `POST /api/enroll` with the UIN, the legal name, the email, the frontal `faceImage`, and, for a live camera, `faceViews`: five pairs of sector, client yaw, and

JPEG. The server refuses a vector supplied by the caller. It builds an ISO/IEC 19794-5 face record inside an ISO/IEC 19785-3 CBEFF document from the JPEG bytes, then runs `embed_face_image`. That function hashes those bytes with SHA-256 and maps the hash onto a 128-dimensional unit vector. The same JPEG always yields the same vector. A different JPEG lands far away. This is a duplicate-image check. It does not recognize a face. A live enrollment stores one vector per sector. A photo stores the single vector under the sector `front`.

The gateway then writes through the IDRepo REST interface. The mock service, not FastAPI, opens SQL. The person, the JPEG text, and the CBEFF XML go to `mosip_idrepo.citizen_identity`. The vectors go to `mosip_ida.face_template`, one row per sector, keyed by UIN. The image stays in the identity row. It is not packed inside the vector. The response that comes back to the page is the status, the UIN, the name, and whether CBEFF was generated. The vector and the JPEG stay on the server.

Login is a second step the diagram does not draw. After the identity is saved, the page can call `POST /api/credentials` with a password the person chooses. That password goes only to Keycloak. It is not written on the identity row.

1.2 1:1 authentication

The lower band of the diagram uses the same browser models, already in memory. Detection and landmarks run again on the live frames or on an uploaded photo. Blink totals and the minimum and maximum eye-aspect ratio stay in the page. The diagram then shows two server calls.

The first is `POST /api/checkLiveness`, and only for a live camera. The page sends a challenge id, a blink count, the EAR range, and a duration. It sends no image and no embedding. `evaluate_liveness` applies thresholds to those numbers: at least one blink, a minimum EAR under 0.25, an EAR change of at least 0.045, and a challenge nonce that is still live. There is no model and no look at the pixels. A still photo, on the diagram, skips this call and sets `livenessPassed` locally. The page keeps the score.

The second call is `POST /api/authenticate`. The diagram sends the UIN, the liveness score and flag, a frontal `liveImage`, and, for a live camera, the five `liveViews`. The server reads the stored 128-dimensional rows for that UIN, hashes each probe JPEG with the same function, and compares them in `matcher.py` by Euclidean distance. On that drawing, a pass is a distance under 0.50 together with a liveness pass. The read is the identity row for the name and email, and the template rows for the stored vectors. Nothing is written. The probe JPEG is not saved. The page is shown a match flag, a distance, a score, and the citizen's name. No vector comes back.

The verify step in the gateway has since moved off that match box. The camera asks for a head-sweep challenge (`POST /api/sweep/challenge`) that lasts 90 seconds and can be used once. Blink detection and `checkLiveness` stay on the page as diagnostics. Skip Blink records an override and does not replace the sweep. A still photo is refused at verification. `POST /api/authenticate` now carries the challenge id and the five views. The server accepts the submission when the challenge is valid, the client yaw labels step from left to right, and the five images are different bytes. It does not estimate yaw from the pixels, and it does not run the distance comparison. `isFaceMatch` and `livenessPassed` stay false. `verified` means the sweep submission was accepted. The diagram's amber match box remains the picture of the hash embedder that enrollment still uses. It is not the decision the authenticate endpoint returns today.

2 Rules that settle the disagreements

1. A pass has three separate answers: the submission was accepted, liveness passed, and the face matched. Each answer comes from the module configured for that check. With the current

head sweep and byte-hash embedder, only the submission answer can be true. The screen, the API, and Keycloak use those words. “Verified,” “biometrics valid,” and a 0.68 match score appear only after the module that owns that check has actually passed.

2. A photo upload can save a draft so a missing camera is not a dead end. It becomes the biometric of record only after the same presentation check the gateway is willing to claim. A person who cannot complete a head turn can finish with an operator-assisted capture. That capture is attributed to the operator and is labeled as assisted.

3. The challenge expires and is single-use, and it can be renewed without clearing the name, the email, or poses already accepted. The form survives a slow network. The timer does not wipe the application.

4. Keycloak is the only place a password is stored. If Keycloak is down, credential issue fails and the IDRepo record stays so the login can be retried. The gateway tells Keycloak that biometrics are valid only after both the presentation check and a real matcher have passed.

5. The mock IDRepo is a deployment choice. If the configured IDRepo cannot be reached, enrollment fails. The gateway does not complete it inside its own process.

3 Accessibility

BR-A-01 Phone and desktop **Partial**

A person can enroll on a current phone browser and a current desktop browser, with the front camera on a phone and the steps still readable when the keyboard is open. **Why.** Citizens and students will use their own phones, shared lab computers, and campus networks. The page has to work in the hand and on a desk.

Acceptance.

- Chrome, Edge, Firefox, and Safari start the flow on both a phone and a desktop.
- On a phone the steps stack in one column, buttons are large enough to tap, and the camera uses the front camera.
- The viewfinder stays available while the person fills in name and email, including when the software keyboard is open.
- A normal desktop window shows the same steps without horizontal scrolling.

BR-A-02 Camera failure **Partial**

A blocked, missing, or slow camera still offers a photo upload on the same screen, in everyday language, without losing the name and email already typed. **Why.** Permission prompts fail, shared computers have no camera, and a denied camera cannot end the application.

Acceptance.

- Denying the camera, or having no camera, shows a short explanation and a visible photo upload.
- The message names the next action in everyday words.
- Upload works when the live face models have not finished downloading.
- After a failed camera start, the name, email, and any photo already chosen are still there.

BR-A-03 Plain language in Thai and English **Missing**

Each step has one plain-language instruction in Thai or English, and the choice stays through enrollment and login. **Why.** This surface is for AIT in Thailand. People recover from the sentence on the screen. Thai and English are the language pair for citizens, students, and the operators helping them.

Acceptance.

- The person can switch language before capture, and the choice stays through enrollment and login creation.
- Thai and English cover buttons, pose directions, camera failure, upload, success, and password rules.
- Errors name the next action. Standards codes and diagnostic readouts stay closed unless someone asks for them.
- A Thai name can be typed and shown back correctly. Success separates "your registration number is saved" from "your login is created."

BR-A-04 Keyboard, screen reader, and contrast **Partial**

Name, UIN, errors, and pose progress work from the keyboard and from a screen reader, and remain readable without relying on color. **Why.** Operators and citizens with low vision still have to enter a name, read the UIN, and know whether a pose was accepted. The UIN is the value the person must keep.

Acceptance.

- Every field has a visible label, and the person can reach every button in order without a mouse.
- Pose progress is announced in words, and errors appear in the page.
- Instructions and the UIN meet ordinary contrast for body text, including on the camera panel.
- Pose success is a word or icon together with color, and the browser can enlarge the page without controls overlapping.

BR-A-05 Motion and direction **Partial**

Blink cues and the head-turn guide respect reduced motion, and "left" means the person's left on a mirrored preview. **Why.** Blink numbers, a moving outline, and a forced sweep are motion prompts. A mirrored preview makes "left" and "right" ambiguous for the person and for an operator standing opposite.

Acceptance.

- If the device asks for reduced motion, the page does not flash the eye readout or animate the guide.
- The person can turn the blink prompt off and still see what the real step is.
- Pose guidance can be a still picture or a short sentence.
- The instruction and a simple diagram use the person's left and right, so an operator can repeat the same direction.

BR-A-06 An alternative to the five-pose sweep **Missing**

A person who cannot complete five head poses is offered an assisted finish before the sweep is required. **Why.** Neck range, a wheelchair headrest, pain, or a phone held by someone else can make the sweep impossible. Upload may save a draft. It does not by itself complete a biometric

check.

Acceptance.

- Before the sweep, the page offers another way to finish for someone who cannot turn their head.
- That alternative is described in the same plain language as the sweep.
- A still photo accepted as a draft is not later treated as a completed biometric check.
- The person is told, in words, when a pose has been accepted.

BR-A-07 Assisted enrollment **Missing**

An operator can assist without the operator's face or name becoming the applicant. **Why.** Shared computers and assisted students are part of the audience. The person typing may not be the person in front of the camera.

Acceptance.

- The helper can mark that they are assisting, and the captured face is confirmed as the applicant before submit.
- The applicant's name is required. The form does not invent a name.
- The helper can read each step aloud without the helper's own face being stored as the applicant.
- On a shared computer, the applicant enters the password themselves.

BR-A-08 Time, pause, and a clear screen **Missing**

The person can pause, retry a pose, and renew a challenge without losing the application, and can clear the screen when finished on a shared computer. **Why.** Slow movement, a translator, and a weak connection are normal here. The same browser will be handed to the next student.

Acceptance.

- A pose, the form, and the login step survive long enough for a slow user. Renewing a challenge keeps the name, email, and poses already accepted.
- A pose that is not accepted explains what is wrong and lets the person try again without clearing the form.
- A slow network shows waiting and keeps what was already entered.
- "Done, clear this screen" removes the name, UIN, photo, and password. The password can be shown while it is chosen, then hidden. The UIN is shown in large type long enough to write down.

4 Security

BR-S-01 What a pass is allowed to mean **Partial**

Until a face matcher is configured, a pass means only that a fresh sweep submission was accepted. **Why.** Calling that result identity verification lets a second person take a UIN. The byte hash detects identical images. A new capture of the same person is a different result.

Acceptance.

- A sweep pass sets a submission flag and leaves identity-match and liveness flags negative.
- No screen, receipt, or Keycloak attribute reads as "face matched" or "biometrics valid" from that pass.
- Operator copy describes the hash check as identical-image detection, and a citizen recapture

is not promised to match an enrolled image.
- Relying parties cannot treat the result as 1:1 ownership of the UIN.

BR-S-02 Single-use challenges **Partial**

Each sweep challenge is single-use, expires, and is consumed on success, expiry, or failure across every instance that can accept a submission. **Why.** A reusable challenge lets an old or copied capture stand in for the person at the camera. A store that lives in one process fails once more than one instance is running.

Acceptance.

- A second submit of the same challenge is rejected.
- An attempt after the window is rejected, and that challenge cannot be reused.
- Challenge state survives restart and is shared by every app instance that can accept a submission.

BR-S-03 A new session needs a fresh capture **Partial**

A stored photo, a screen replay, or an earlier sweep file cannot satisfy a new session. **Why.** Replay is a direct path to a recording, or a second person, standing in for the applicant.

Acceptance.

- Images submitted for a challenge are bound to that challenge's issuance.
- A repeated identical byte sequence across poses is rejected.
- Once the product claims that the head turned, that claim is based on a measurement of the capture.
- Client pose labels alone do not establish a live turn.

BR-S-04 The password stays in Keycloak **Partial**

The password is collected only at credential issue and is stored only in Keycloak. **Why.** A breach of the biometric store must not also reveal the login secret. A password reset must not require reading the face record.

Acceptance.

- Enrollment rejects any password field.
- An IDRepo read of the UIN after credential issue shows no password.
- A failed identity-provider write does not leave the password in the identity store.
- The citizen is told that the login was created only when Keycloak has the user.

BR-S-05 Who may see a face **Missing**

A raw face image or its CBEFF package is readable only by a role whose job requires it, for a stated purpose and retention period. **Why.** The identity record is a national biometric. Broad read access turns every operator and every debug tool into a copy of a citizen's face.

Acceptance.

- Retrieval of the raw image or CBEFF is denied without an authorized role.
- Logs, command-line output, and support tools do not print image bytes.
- Retention of the raw image has an explicit purpose and an expiry or deletion path once a real template exists.

BR-S-06 Consent before capture **Missing**

The camera opens only after the person has agreed to capture, the purpose, and who can see the image. **Why.** A national onboarding gateway that captures a face needs a record of agreement before it holds the image or shares it with an identity provider.

Acceptance.

- Enrollment is rejected when no consent record is present.
- The record names the purpose, the time, and the language version the person saw.
- Refusal leaves no face image stored.

BR-S-07 An override is an exception **Partial**

A blink override is an attributed exception. It cannot enroll a face, pass a sweep, or issue a login by itself. **Why.** Operator substitution is a way for a clerk to complete onboarding for someone who is not present.

Acceptance.

- A blink override is stored with operator identity, time, and reason, and it is labeled a diagnostic override.
- Authenticate still requires the sweep submission check.
- Enrollment and credential issue do not succeed on the override alone.

BR-S-08 Audit of enroll and credential issue **Missing**

Every enrollment and credential issue writes an audit entry that survives restart and omits the face bytes and the password. **Why.** A disputed UIN or a fraudulent login cannot be investigated if the only trace disappears on restart.

Acceptance.

- Successful and failed enroll and credential-issue events are queryable after process restart.
- The entry includes actor, UIN, timestamp, and result, and excludes image bytes and the password.
- An auditor can see whether biometrics were claimed valid at issue time.

BR-S-09 The same bar for storing a face **Missing**

A face is stored as the biometric of record only after the presentation check the product claims, and a packaging failure does not keep a raw image as a silent fallback. **Why.** A photo enrolled now becomes the reference a future matcher will trust. A weak enroll permanently arms a false accept.

Acceptance.

- Enrollment without an accepted presentation check does not write a biometric of record.
- The stored image is the one from that check.
- If image packaging fails, the raw image is kept only under an explicit, audited exception.

5 Modularity

BR-M-01 IDRepo writes the citizen — Partial

Only IDRepo creates or updates the citizen record. The gateway submits demographics, the CBEFF document, and server-built templates. **Why.** Later products will read the same person. A private copy inside the gateway will disagree with MOSIP about who exists.

Acceptance.

- After enrollment, the UIN, name, email, and biometrics are readable from the IDRepo interface the environment points at.
- The enrollment screen keeps one destination when the team moves from the mock to real MOSIP.
- A credential request that fails leaves the IDRepo record in place.

BR-M-02 Keycloak writes the login — Partial

Only Keycloak stores the login. A credential call for an unknown UIN creates no user. **Why.** eSignet and Inji depend on the realm account. AIT can change Keycloak without reopening the biometric record.

Acceptance.

- Enrollment completes with no password and no Keycloak user.
- The credential call sends the chosen password only to Keycloak, after it has confirmed the UIN exists.
- Repeating the credential call for that UIN does not create a second identity.
- The caller can tell a filed citizen from a citizen whose login exists.

BR-M-03 Mock or real MOSIP by configuration — Partial

Mock versus real MOSIP is selected by configuration, and an unreachable IDRepo fails the operation. **Why.** Demos run on the mock now. The same enrollment must later point at real MOSIP. A silent substitute files citizens in the wrong place.

Acceptance.

- The mock substrate starts only when that overlay is selected.
- With the real base URL set, enrollment is attempted only against that URL.
- If the configured IDRepo cannot be reached, enrollment fails and no second identity is created inside the gateway.
- Staging and production use the same deployment job. Only environment values change.

BR-M-04 No direct database access — Met

The gateway reaches identity and login stores only through their published interfaces. **Why.** Real MOSIP will not give this gateway database credentials. SQL that leaks into the gateway has to be removed when the ministry's IDRepo arrives.

Acceptance.

- Enrollment, credential issuance, and authenticate still succeed in a test when the gateway process has no database password.
- The identity service is the component that uses the identity database.
- Swapping the mock service for real MOSIP does not require the gateway to learn a new table layout.

BR-M-05 Replaceable checks — Missing

The presentation check, the template engine, and the matcher can each be replaced by configuration without changing the citizen form. **Why.** PAD and the face model will move onto services other teams own. Agencies cannot wait for a form redesign each time the model or the threshold changes.

Acceptance.

- The browser still posts a face image and demographics, and the server still refuses a template supplied by the browser.
- Authenticate returns the liveness result of the active presentation module and the match result of the active matcher.
- Replacing either module leaves the IDRepo write and the Keycloak credential call on the same two steps.
- A matcher outage leaves the enrolled UIN and any existing Keycloak user unchanged.
- Templates already stored stay comparable under a published rule, or they are marked as requiring re-enrollment.

BR-M-06 Downstream systems keep their own records — Partial

eSignet, Inji, and AI-BioSDK keep their own records. The gateway integrates through their interfaces. **Why.** Those products belong to other workstreams and ship on their own cycle.

Acceptance.

- No gateway setting contains a connection string for eSignet, Inji, or AI-BioSDK storage.
- Issuing a login produces a Keycloak user that eSignet can use, without the gateway writing into eSignet's store.
- A future match call sends a probe and receives a decision from AI-BioSDK.
- Enrollment completes while Inji is absent.

BR-M-07 Django and Celery stay off the identity path — Met

Filing a citizen, issuing a login, and verifying a person finish without Django or Celery. **Why.** Staging and production share one deployment. A queue or an admin site on the critical path becomes another system every environment must run before a person can enroll.

Acceptance.

- With the Celery worker and Django site stopped, enroll, credential issuance, and authenticate behave as they do with them running.
- A deployment checklist for staging does not require a worker or a Django migration for identity.
- If a later requirement introduces a queue, the citizen still receives a clear pending or failed outcome.

BR-M-08 One owner per piece — Partial

AIT owns the onboarding flow. IDRepo owns the citizen file. Keycloak owns the login. The PAD provider owns the liveness decision. The BioSDK owner owns the template and the match. **Why.** Unclear ownership turns every swap into a rewrite of enrollment.

Acceptance.

- A face-model release does not require an enrollment-screen change.

- A realm change does not require an IDRepo schema change.
- A PAD change does not require a new credential flow.
- One named owner accepts or rejects a production swap of each piece.

6 Standardization

BR-T-01 UIN is the only citizen identifier

Partial

The only citizen identifier is a UIN from the MOSIP ID generator, and enrollment, verify, and Keycloak all use that value. **Why.** IDRepo, IDA, and the Keycloak `mosip` realm join a person on the UIN. A second number will not resolve in those systems.

Acceptance.

- A new citizen receives a UIN only from the MOSIP ID generator.
- Lookup, verification, and credential handoff use that same UIN.
- A caller-chosen string is rejected.
- If the generator is unavailable, no local number is minted and the person is not told they are enrolled.

BR-T-02 A small demographic set

Partial

The IDRepo identity for a portal release contains only UIN, legal name as a language-tagged value, and email, under a named ID schema version. **Why.** Real IDRepo validates the identity against an ID schema. An attribute the schema does not define is rejected, so later matchers never see a record that only the mock accepted.

Acceptance.

- A successful enrollment shows UIN, full name as a language-and-value pair, and email, and names the ID schema version that was applied.
- A subsequent read returns those same attributes.
- Portrait bytes, timestamps, and match vectors stay out of the demographic object.

BR-T-03 CBEFF is the biometric of record

Partial

The biometric of record is one CBEFF face document, format owner 257 and format type 8, wrapping an ISO/IEC 19794-5 face image that a MOSIP parser accepts. **Why.** Format owner 257 and type 8 are how MOSIP IDA and a later BioSDK recognize a face record. A private list of numbers is not a biometric they can open.

Acceptance.

- After enrollment, a read of the identity returns a biometric document whose format owner is 257 and whose format type is 8.
- The biometric data block is an ISO/IEC 19794-5 face image a MOSIP parser accepts.
- The server builds that record from the captured image. A caller-supplied vector is refused.
- A shortened private header, a fixed quality score, or a sidecar embedding list is not the record IDA is asked to read.

BR-T-04 The published IDRepo contract **Partial**

Create and read use the published MOSIP IDRepo v1 contract. A payload real IDRepo would reject fails enrollment. **Why.** A body that only the mock understands fails on a real IDRepo, so the UIN never becomes a record the rest of MOSIP can use.

Acceptance.

- Create uses the MOSIP identity envelope and the published identity plus the biometrics document. Read uses the UIN identity route.
- A payload that real IDRepo rejects fails the enrollment. The citizen is not told they are enrolled.
- The mock's extra template list and raw-image fields remain a test double.
- A remote rejection is shown as a failure.

BR-T-05 Claims match the check that ran **Partial**

The portal says enroll, verify, and credential issue for three different outcomes, and claims ISO/IEC 30107-3 or a matcher score only when that check produced the result. **Why.** IDA and a future matcher will trust a liveness label and a score as evidence. A label with no evaluation becomes a false input. Partners will look for a biometric decision that was never produced if the head sweep is named authentication.

Acceptance.

- Enroll returns an IDRepo result and does not take a password or claim a Keycloak account.
- Verify returns only a verification result. Credential issue returns only whether the realm user was created for that UIN.
- The head sweep is described as a submission check, and liveness stays negative while that is the check in force.
- A cosine threshold, including 0.68, is shown only together with the matcher, the comparison, the score, and the threshold that were applied.

BR-T-06 Credential issue stops at Keycloak **Partial**

The credential step creates a `mosip` realm user whose UIN attribute matches the IDRepo UIN, and stops there. **Why.** eSignet resolves the person through that attribute. A credential format invented here would diverge from the credential eSignet and Inji issue later.

Acceptance.

- After credential issue, the realm user carries the same UIN as the identity record, and the password exists only in Keycloak.
- Documentation names eSignet and Inji as downstream consumers of that UIN.
- This product does not issue an OIDC token or an Inji verifiable credential.
- The realm user is not marked biometrics-valid until the presentation check and a real matcher have both passed.

BR-T-07 A versioned portal contract **Missing**

Citizen-facing behavior is published as a portal API version, separate from the MOSIP envelope version. **Why.** IDRepo, IDA, and Keycloak will keep their own contracts while this portal changes. Partners need to know which portal behavior produced a UIN and a biometric record.

Acceptance.

- The portal contract in use carries a version, and that version's field set, identifier rules, and result meanings are written down.
- Two calls on the same version return the same shapes for enroll, verify, and credential issue.
- The field set, the UIN rules, and the meaning of a pass stay fixed inside one portal version.
- The MOSIP envelope version is not reused as the name of the portal API.

BR-T-08 Staging and production make the same promise Partial

Staging and production expose the same UIN rules, the same demographic set, the same CBEFF biometric, and the same claim wording. **Why.** Production IDRepo will accept only the published contract. A looser staging mock trains operators to rely on behavior production will reject.

Acceptance.

- The same portal version, field set, and claim wording are what smoke-tested staging and production expose.
- A record accepted in staging is one the production IDRepo contract would accept.
- Staging is described as the mock while it is still the mock.

7 Where the prototype stands

Two requirements are already met. The gateway reaches identity and login stores through their published interfaces (BR-M-04). Django and Celery are off the enrollment path (BR-M-07).

The open gaps are consent before capture, an audit trail, restricted access to face images, an assisted path for people who cannot complete the sweep, Thai and English copy, a versioned portal contract, and a presentation check and matcher that can be selected by configuration without rewriting the enrollment form.

Source note. This document consolidates four parallel reviews of the repository on 12 November 2026: accessibility of the browser flow, security of proofing and credentials, modularity of IDRepo, Keycloak, and the biometric checks, and standardization against the MOSIP identity contract. Status labels describe that prototype. They are not a certification.